



CYBERSECURITY TRAINING SESSION

Zero Trust Management

“Never Trust, Always Verify”



Identity

Device

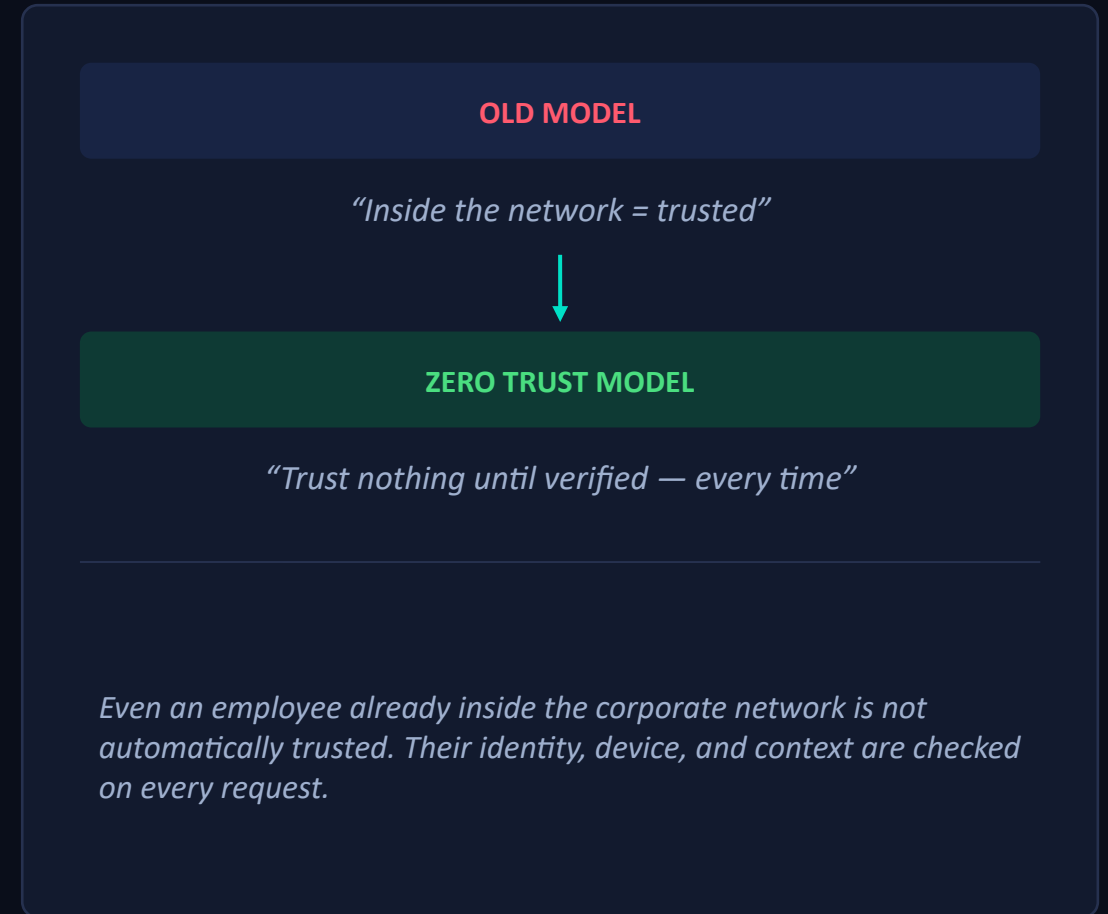
Network

Application

Data

What is Zero Trust?

- A security model built on one rule: never trust automatically
- No implicit trust for any user, device, or system
- Every access request is verified, regardless of location
- Validation happens continuously, not just at login
- Access is granted using least privilege



Why Do We Need Zero Trust?



Cloud Apps

SaaS platforms outside the traditional network



Remote Work

Employees connect from homes, cafes, airports



BYOD

Personal phones and laptops access company data



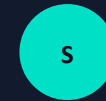
Mobile

Access happens anywhere, anytime, any device



Insider Risk

Threats can come from trusted accounts too



Stolen Creds

Passwords are phished, leaked, and reused

Traditional Security vs. Zero Trust

	TRADITIONAL PERIMETER	ZERO TRUST
Trust model	Trust inside the network	Verify continuously, everywhere
Access basis	Network location / perimeter	Identity-centric
Remote access	VPN-based access	Context-aware, per-request access
Controls	Static controls	Dynamic, least-privilege controls
After login	Broad access once authenticated	Continuous monitoring & re-checks

The Core Principle

“Never Trust, Always Verify”

- Every request is treated as potentially untrusted
- Authenticate — confirm who is asking
- Authorize — confirm what they may access
- Validate context — device, location, risk
- Monitor continuously — re-check throughout the session



A request only becomes access after passing every check.

Three Core Principles of Zero Trust

1

Verify Explicitly

Always authenticate and authorize using every available data point — identity, device, location, and behavior.

EXAMPLE

Login requires MFA plus a device-health check, not just a password.

2

Least Privilege Access

Give users only the access they need, limited in scope and, where possible, time.

EXAMPLE

A contractor gets read-only access to one project folder for 30 days.

3

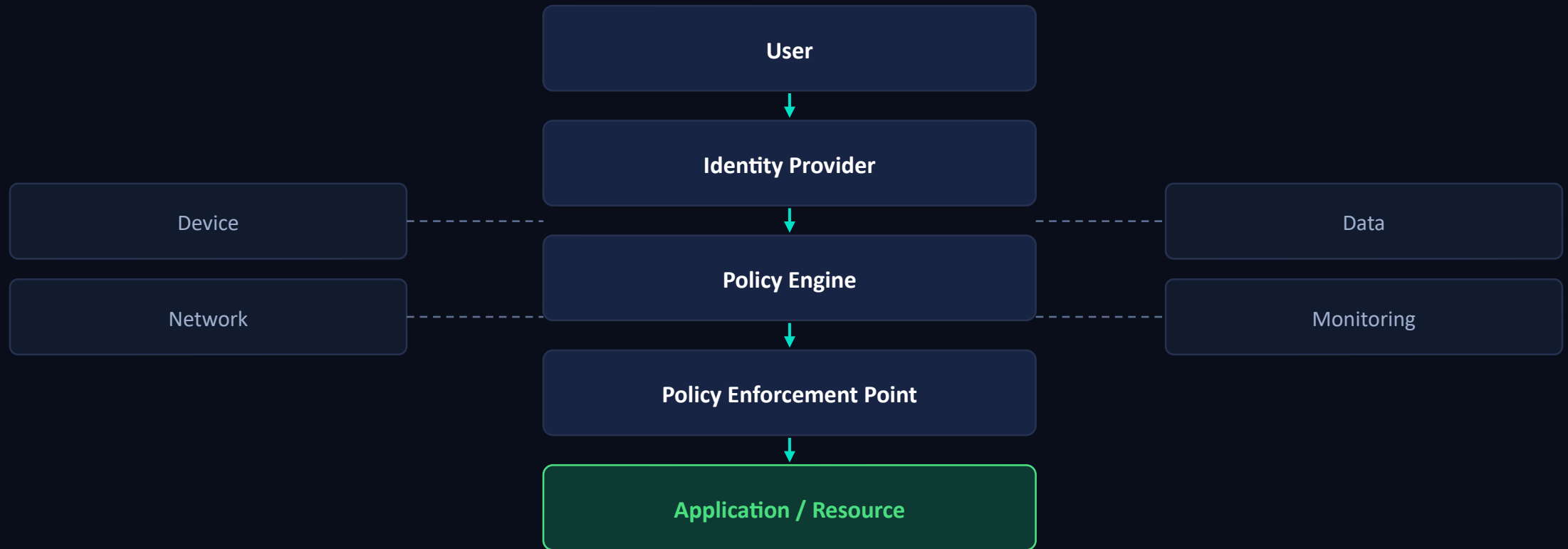
Assume Breach

Design as if an attacker is already inside — segment access and monitor continuously.

EXAMPLE

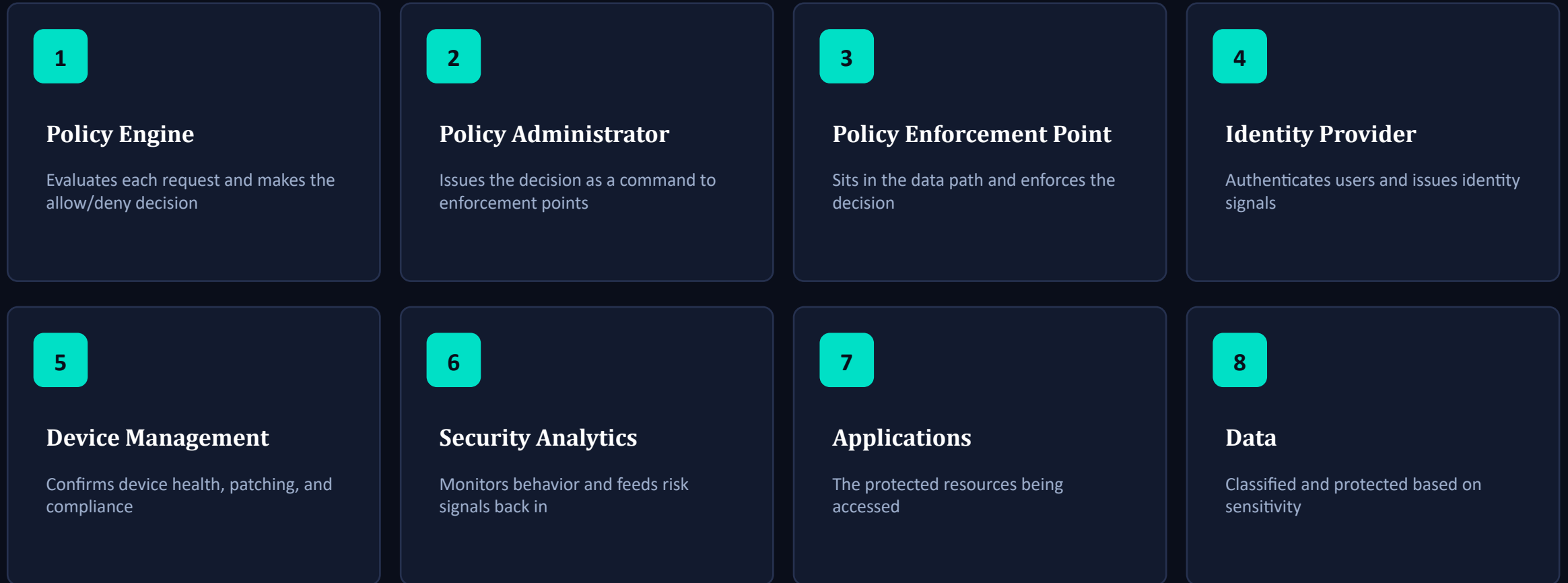
One compromised laptop cannot reach the entire internal network.

Zero Trust Architecture



Threat Intelligence feeds the Policy Engine with real-time risk signals.

Zero Trust Reference Architecture



Identity Is the New Perimeter

- User identity is the primary control point
- Strong authentication confirms who is asking
- MFA adds a second layer beyond passwords
- SSO simplifies secure access across apps
- IAM governs accounts, roles, and permissions
- Risk-based authentication adapts to context
- Privileged identities need extra scrutiny



Real-World Example

An employee logs in from a device that has never been seen before, from a country they have never traveled to.



Traditional model

Access likely allowed once password is correct



Zero Trust model

Risk score rises → step-up MFA is triggered

Authentication vs. Authorization

AUTHENTICATION

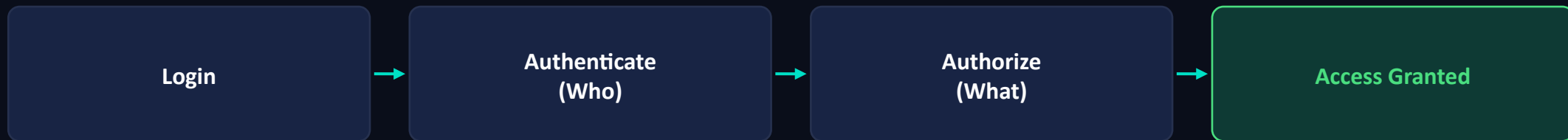
“Who are you?”

Username/password, MFA, biometrics — proving your identity.

AUTHORIZATION

“What can you access?”

RBAC and application permissions — defining allowed actions.



Multi-Factor Authentication (MFA)



Something You Know

Password / PIN



Something You Have

OTP / Authenticator / Security Key



Something You Are

Biometrics — fingerprint, face

MFA strengthens the “Verify Explicitly” principle by requiring more than one proof of identity before access is granted.

Least Privilege

- Users receive only the access required for their role
- Access is scoped as narrowly as possible
- Time-bound access where feasible
- Privileged/admin access is tightly controlled and audited

ROLE → ACCESS MAPPING

HR Employee	→	HR Application
Developer	→	Development Environment
Finance Employee	→	Finance Application

⚠️ Why “everyone gets admin” is dangerous

One compromised account with broad admin rights can expose the entire environment — the blast radius of any single breach grows dramatically.

Device Trust / Device Security

- Zero Trust evaluates the device before granting access
- OS version and patch status
- Antivirus / EDR presence and health
- Disk encryption status
- Device compliance policy
- Managed vs. unmanaged device



Same User + Compliant Laptop

Patched, encrypted, EDR active → Access Allowed



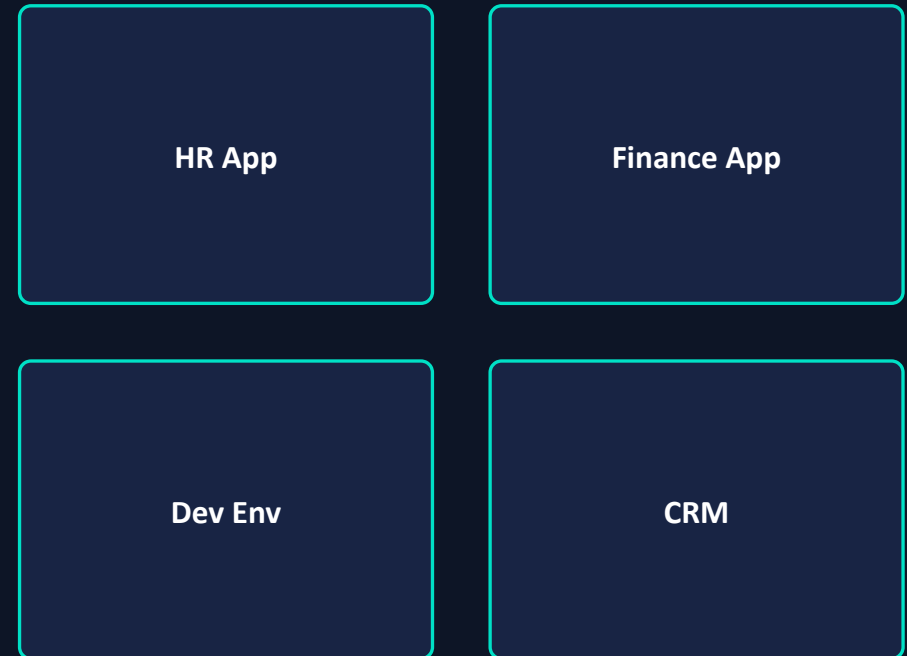
Same User + Compromised Laptop

Out of date, no EDR → Access Blocked / Restricted

Network Security in Zero Trust

- Network segmentation limits lateral movement
- Micro-segmentation isolates individual workloads
- Software-defined perimeter hides resources by default
- Secure remote access replaces flat VPN access
- Continuous monitoring of network traffic

MICRO-SEGMENTED NETWORK



Each segment enforces its own access policy — a breach in one cannot freely reach another.

Application Security

- Application-level access control
- API security and gateway enforcement
- Secure authentication for every app
- Session management and timeouts
- Application segmentation

KEY TECHNOLOGIES

1

OAuth 2.0

2

OpenID Connect

3

API Gateways

4

SSO

These technologies connect identity decisions directly to what an application allows a user to do.

Data Security

- Data classification by sensitivity
- Encryption at rest and in transit
- Fine-grained data access control
- DLP — Data Loss Prevention
- Continuous data-access monitoring
- Data-centric security, not just perimeter security



Public

Freely shareable



Internal

Employees only



Confidential

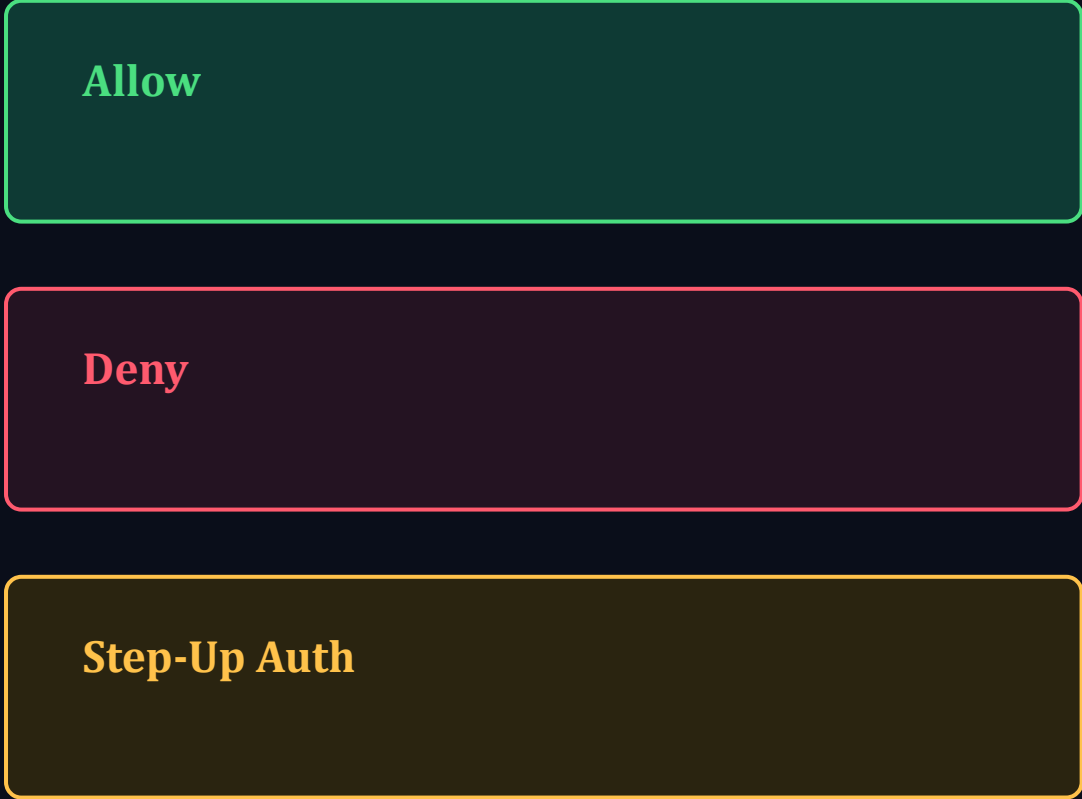
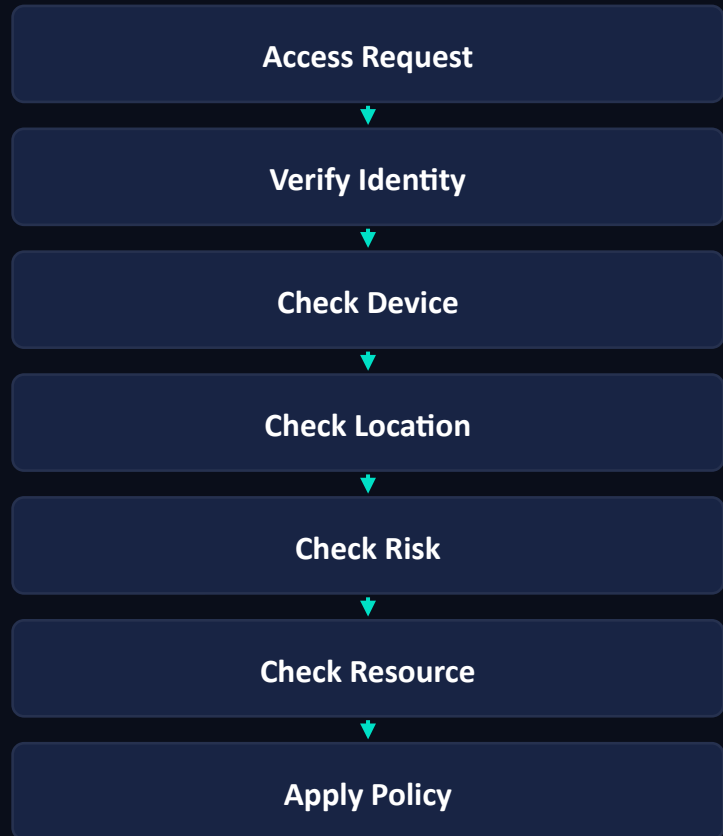
Need-to-know basis



Restricted

Highest sensitivity

Continuous Verification



Authentication is not a one-time event — it happens continuously, throughout the session.

Risk-Based / Context-Aware Access

- User identity & role
- Device health
- Location
- Time of access
- Application sensitivity
- Data sensitivity
- User behavior patterns
- Threat intelligence

LOW RISK

Normal login from the office network, known device, business hours

→ Access Granted

HIGH RISK

Unusual login, unknown device, accessing a sensitive application

→ MFA Challenge / Block

Zero Trust Management

Policy Management

Identity Management

Device Management

Access Management

Security Monitoring

Risk Management

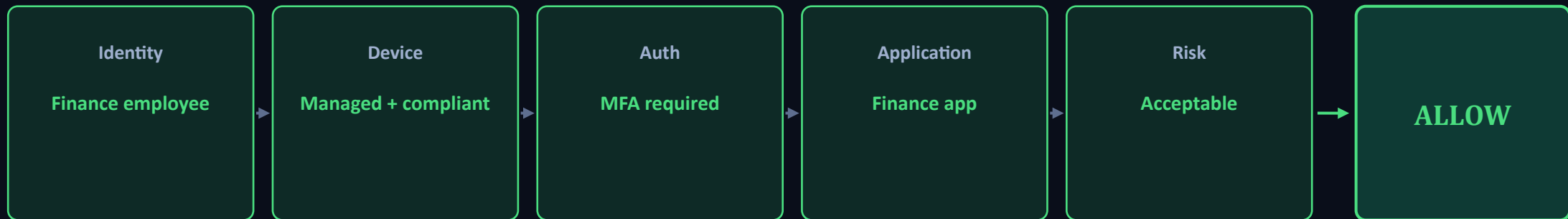
Incident Response

Compliance

These eight areas work together as one continuous management cycle — not isolated tasks.

Zero Trust Policy Example

“Finance application can only be accessed by Finance employees using compliant, managed devices with MFA.”



If ANY condition fails — e.g. an unmanaged device or missing MFA — the request is automatically denied or challenged, regardless of a correct password.

Zero Trust Technologies

Identity

IAM • SSO • MFA • PAM

Device

MDM • EDR • Device Compliance

Network

Firewall • ZTNA • Micro-segmentation

Application

API Gateway • WAF • OAuth / OIDC

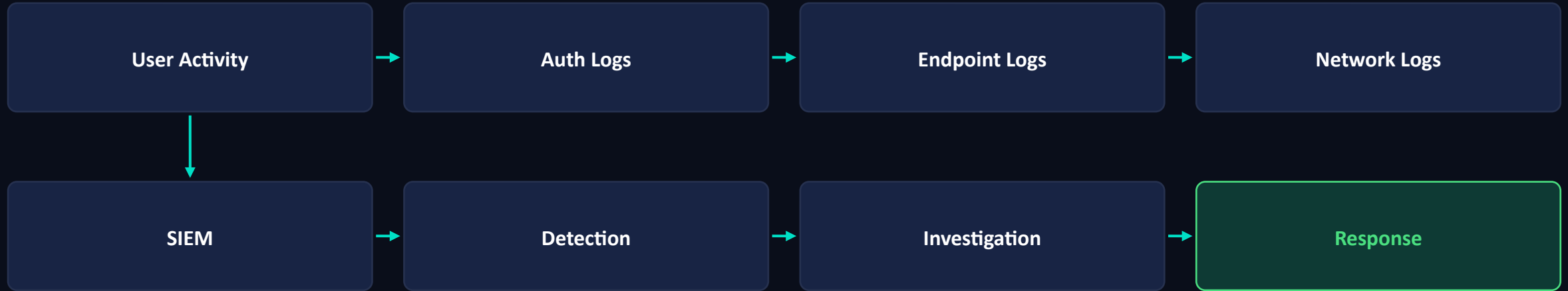
Data

DLP • Encryption

Monitoring

SIEM • SOAR • UEBA

Zero Trust + Security Operations Center



Common SOC Platforms

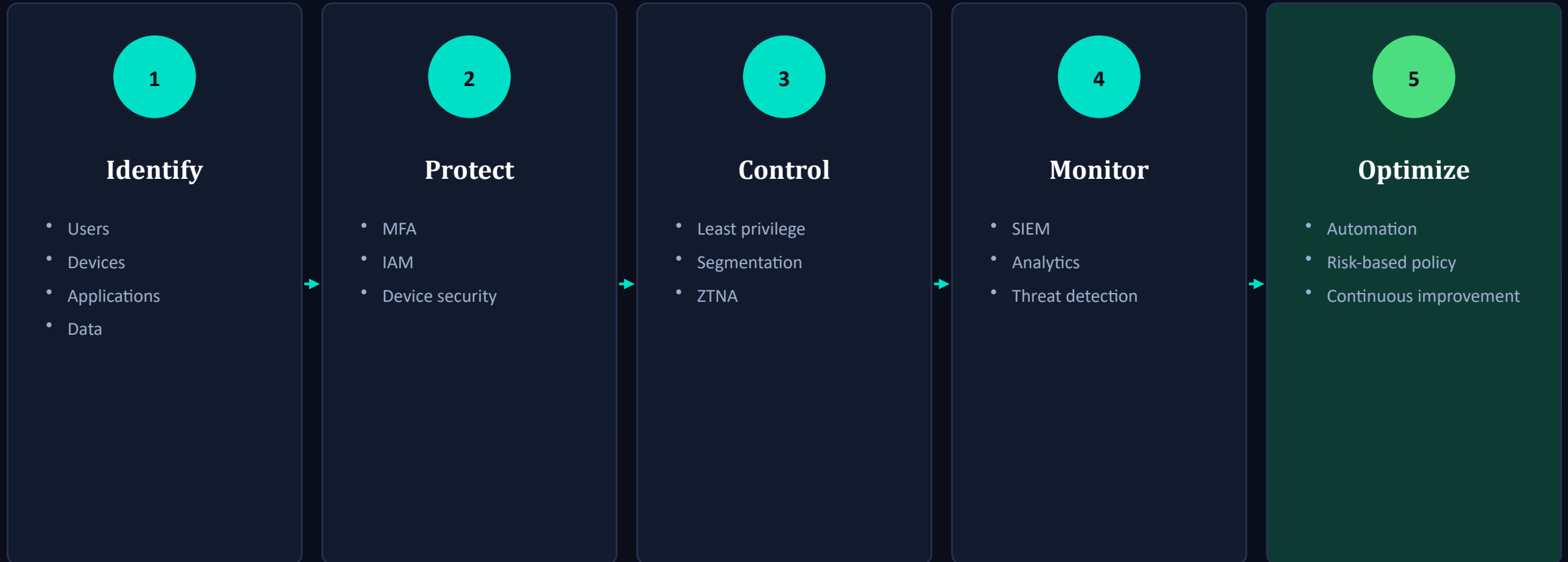
Wazuh

Microsoft Sentinel

Splunk

SOC analysts correlate Zero Trust signals to spot suspicious access behavior, such as repeated denied requests or impossible-travel logins.

Zero Trust Implementation Roadmap



Challenges & Common Mistakes

COMMON MISTAKE	BETTER APPROACH
Legacy apps left unaddressed	Wrap legacy apps with a proxy / gateway
Poor asset inventory	Start with full discovery of users, devices, apps
Excessive standing permissions	Apply least privilege, review access regularly
Misconfigured policies	Test policies in monitor-only mode first
No monitoring after rollout	Pair every control with continuous monitoring
Ignoring user resistance	Communicate early, phase the rollout

Additional factors to plan for: integration complexity, implementation cost, and operational overhead.

Real-World Scenario & Key Takeaways

Scenario

“An employee wants to access a sensitive financial application from a new laptop.”

- | | |
|----------------------------|---------------------|
| 1 Verify identity | 2 MFA |
| 3 Check device | 4 Check location |
| 5 Check risk | 6 Check permissions |
| 7 Apply least privilege | 8 Monitor session |
| 9 Re-evaluate continuously | |

KEY TAKEAWAYS

- Never trust automatically
- Verify explicitly
- Use least privilege
- Assume breach
- Continuously monitor and adapt